



Chakravyuh

Intercept the scam workflow, not the transaction.

TRACK 02 · AI-DRIVEN SCAM PATTERN RECOGNITION

A stateless kill-chain decision engine for UPI + banking sessions.
20 device / bank / network signals fused into 4 kill-chain stages,
capped and gated so a workflow — not a signal — is what triggers action.
Every decision comes with a specific reason and a signed audit receipt.

94.4%

scam recall (8-world mean)

3.4 / 1k

interruptions to legit users

₹5,982 cr

upper-bound saving / yr @ 30M users

25 μ s

engine latency per session

Team

Mathews V Manoj · Muthoot Institute of Technology and Science (KTU)
B.Tech, Electronics & Communication Engineering · 24ec357@mgits.ac.in

One PDF · 10 pitch slides + 3-page architecture + appendix

India runs on UPI. AI-scaled scams are catching up.

Real-time payments + AI-generated pretexts have collapsed the time users have to notice they are being defrauded.

₹22,845 cr

lost by Indians to cyber fraud, 2024

MHA, Lok Sabha, 22 Jul 2025 · 36.37 lakh complaints

+206%

YoY growth in fraud losses

vs. ₹7,465 cr in 2023

₹981 cr

UPI fraud in FY25

12.64 lakh incidents · RBI Annual Report 2024-25

Why yesterday's rules stopped catching this

- AI-cloned voices and deepfaked video calls set a trusted pretext in under 60 s.
- Rented mule accounts (many young, some aged) absorb the money before rules react.
- The victim now sends the money themselves — every fraud-detection rule built for card fraud misses this.
- One-signal rules ('new payee + high amount') fire on rent day, hospital day, gadget day. 20+ FP per real scam.

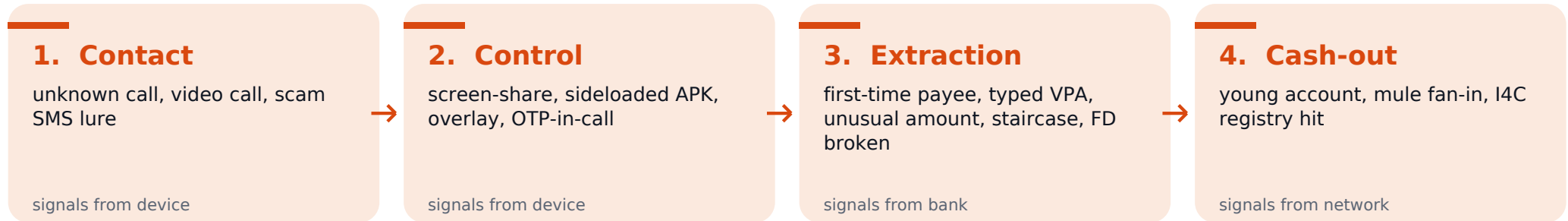
"The fraudster no longer sends money — the victim does. So we score the workflow, not the transaction."

The design premise of Chakravayuh

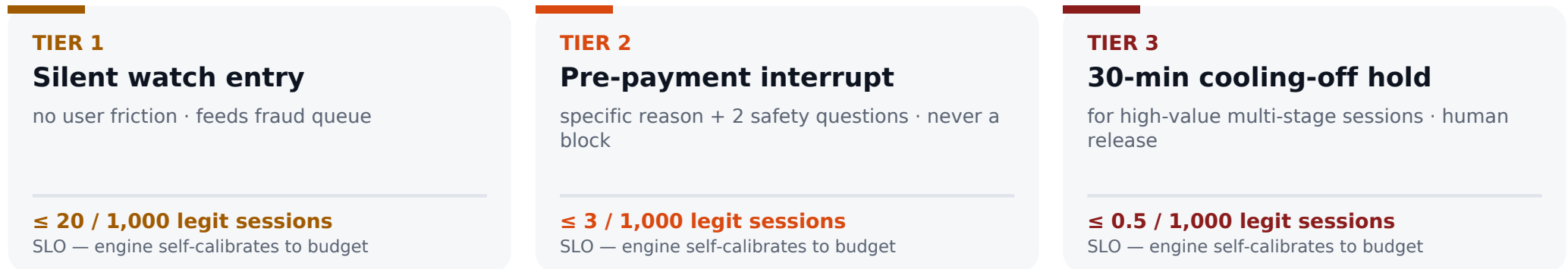
One sentence, four stages, three interventions

Chakravayuh reads a payment session as a kill chain, and interrupts only when a *workflow* forms.

The kill chain we watch



Three interventions on a bank-set alert budget



Before and after — the actual user beat

Same victim, same scammer, two futures. Mocked screens are drawn from the live decision engine.

TODAY · NO CHAKRAVYUH

Mrs R (68) receives a WhatsApp video call

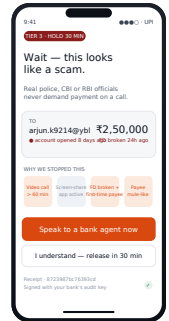
- Fake CBI officer video-calls; says she is named in a money-laundering case.
- Tells her to install AnyDesk 'for verification'.
- Asks her to break her FD 'for asset freeze' and pay to a personal VPA.
- Bank rule (new payee + high amount) shows a soft warning. She reads it aloud on the call. She proceeds.
- ₹4,20,000 lost. NCRP complaint next morning. Recovery: rare.

WITH CHAKRAVYUH

Engine sees the kill chain — hold before PIN

- 3 stages active in ≤ 60 s: video call + FD broken + first-time payee to a mule-like young VPA.
- Tier-3 cooling-off hold fires before the PIN prompt opens.
- Signed decision receipt reaches the bank agent desk with the same explanation.
- She calls her son; agent releases the hold (dual auth) or reports the payee to I4C.
- If she still wants to pay, she can — after a 30-min review + a branch video-KYC.

WHAT SHE SEES

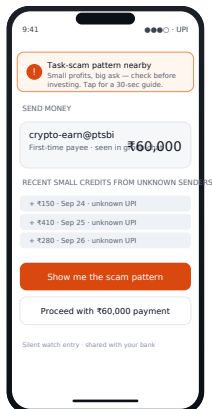


Three intervention tiers, three screens

The same engine — different friction based on how much of the kill chain has fired.

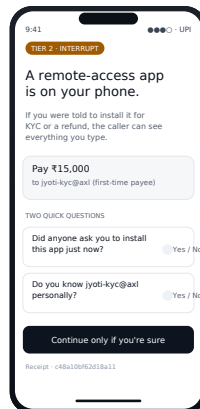
TIER 1 · silent nudge

task-scam pattern nearby; user can proceed or read the guide



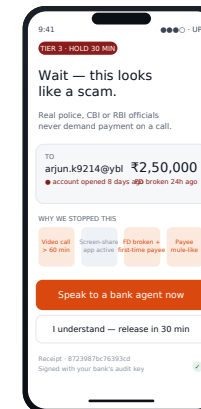
TIER 2 · interrupt (2 questions)

remote-access app detected; user answers 2 pre-pay safety questions



TIER 3 · cooling-off hold

3 stages fire on a high-value session; 30-min hold with agent flow



How a session gets its score

Additive, non-negative evidence per stage, gated by a kill-chain rule. No black boxes.

Session score $s(x)$

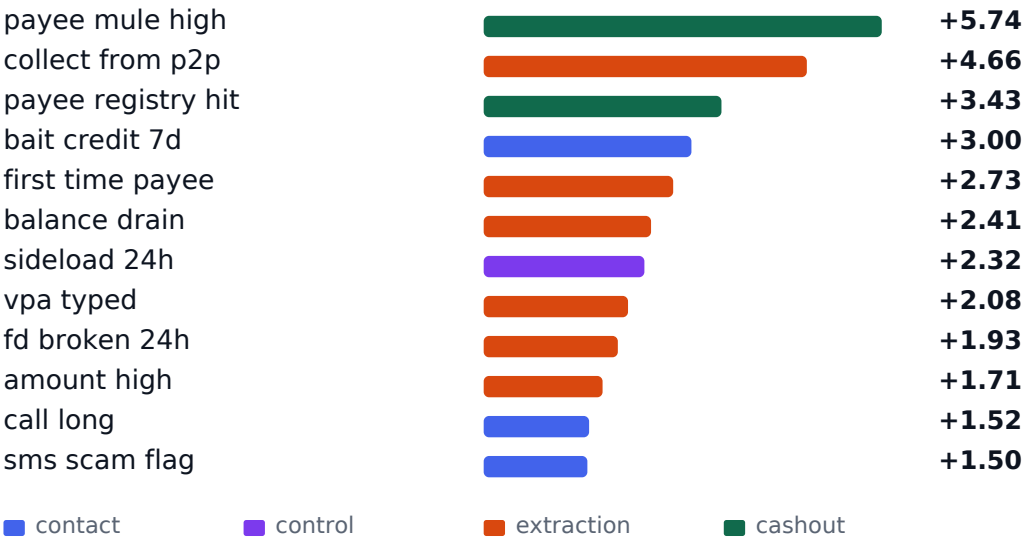
$$s(x) = \text{prior} + \sum_{\text{stage}} \min(\text{cap_stage}, \sum_k w_k * x_k)$$

20 binary signals · non-negative weights · capped per stage · gated by chain

- w_k learned by L2-regularised logistic regression on bank-labelled sessions.
 - Weights are clipped to ≥ 0 so absence of a signal never accumulates suspicion (a fraudster can always suppress a signal — absence must not exonerate either).
 - Each stage is capped so a single stage cannot breach a tier alone.
 - Tier 2 needs ≥ 2 active stages. Tier 3 needs ≥ 3 stages, or 2 stages + registry hit.
 - Prior is shifted from training prevalence to real prevalence (1 in 5,000).
- Thresholds are then self-calibrated on a held-out validation world to hit the bank's chosen alert budget (default: 3 interruptions / 1,000).

Top learned weights (log-odds)

Each weight has a plain-English explanation shown to users and agents.



What the engine reads — and what it never sees

20 signals, one catalogue. Raw content stays on-device.

Contact & pretext

- **call unknown active**
You are on a call with a number not in your contacts while paying
- **call long**
That call has lasted more than 20 minutes
- **video call**
A video/VoIP call is active (common in 'digital arrest' scams)
- **sms scam flag**
A message received in the last 24h matches a known scam lure (KYC, parcel, electricity)
- **bait credit 7d**
Small 'profit' credits from unknown senders in the last 7 days

Control & isolation

- **remote access**
A screen-sharing / remote-control app is running
- **sideload 24h**
An app was installed from outside the Play Store in the last 24h
- **accessibility overlay**
A non-system app can read your screen and draw over the payment app
- **otp read in call**
An OTP was opened while the unknown call was active

Money extraction

- **first time payee**
You have never paid this account before
- **amount high**
Amount is far above your usual payments
- **amount very high**
Amount is extremely high for you (top 0.1% of your history)
- **balance drain**
This payment empties more than 70% of your balance
- **staircase**
Several payments to new accounts in the last 60 minutes
- **fd broken 24h**
A fixed deposit was broken / loan taken in the last 24h
- **vpa typed**
Payee was typed or pasted instead of scanned or picked from contacts
- **collect from p2p**
This is a 'collect' request from an individual (entering PIN SENDS money)

Mule / cash-out

- **payee mule high**
The receiving account behaves like a mule account (many unrelated senders, money moved out fast)
- **payee new account**
The receiving account was opened less than 30 days ago
- **payee registry hit**
The receiving account is on the I4C / bank suspect registry

Privacy contract · DPDP Act 2023 · RBI Master Direction on Digital Payment Security Controls (2021)

From the device only 9 booleans + amount + hashed payee VPA leave: call/video state buckets, screen-share/overlay/sideload booleans, on-device SMS scam classifier outcome (regex + logistic model, no LLM). The 7 bank-side signals (first-time payee, amount z-score, staircase, FD/loan flag, bait credits) are computed inside the bank on data it already holds. The 4 network signals (payee mule score, account age, I4C registry hit, collect flag) are looked up in the bank's own feature store. Raw call audio, message text, screen frames, contact list and app inventory NEVER leave the device — including to Amazon. Signed receipts are the only artefact stored (7-yr RBI audit horizon).

Does it work? — headline results with confidence intervals

Trained on world seed 7 · evaluated on 8 independent unseen synthetic worlds · alert budget 3 / 1,000

94.4%

scam recall (tier ≥ 2)

95% CI [94.0%, 95.0%] · n=8 worlds

3.41 / 1k

interruptions to genuine users

95% CI [3.30, 3.54]

0.981

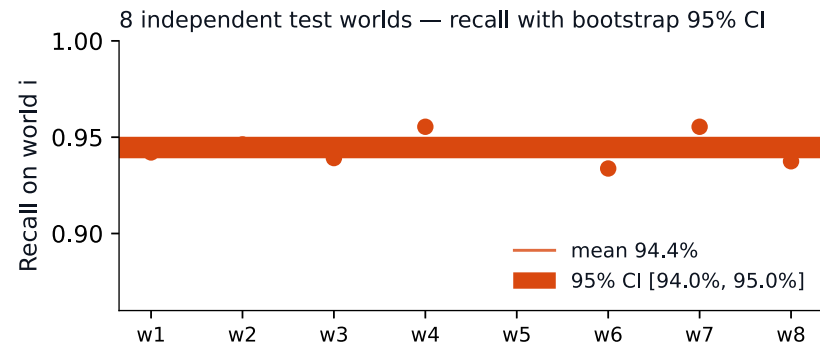
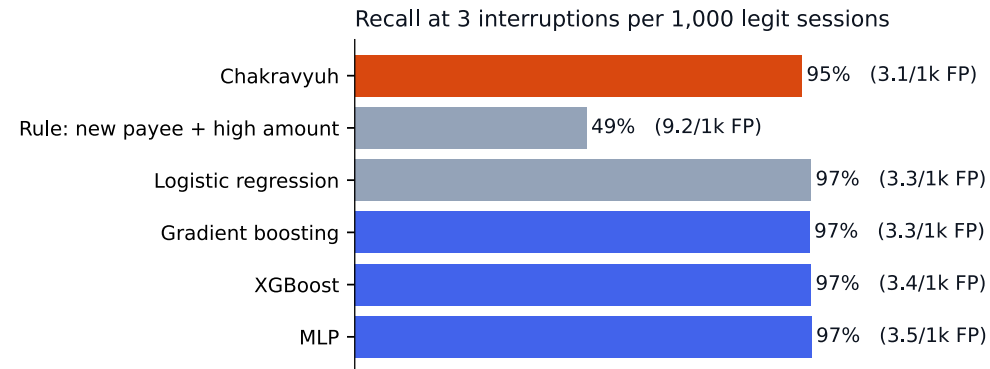
AUPRC · area under precision-recall

vs. 0.986 for XGBoost — we match a black box

₹5,982 cr

upper-bound saving @ 30 M users

projection · full assumptions & limits in Slide 9 + Appendix



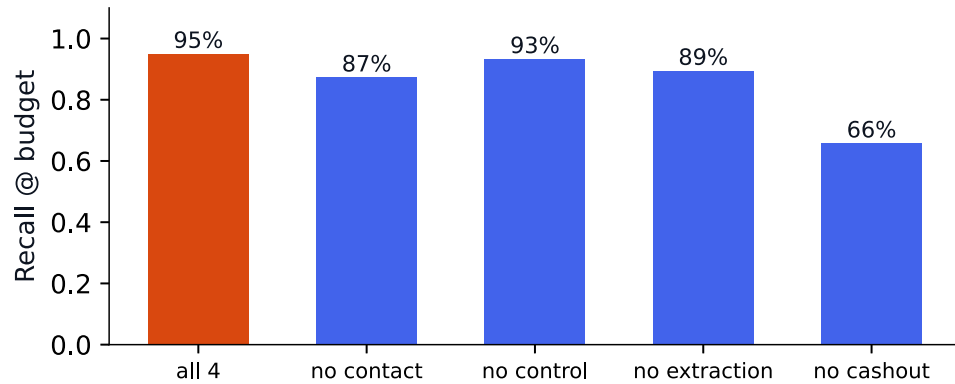
How to read this

Top: same-budget comparison against 5 baselines — we match the best black boxes within 2 pp of recall while keeping per-signal explanations. Bottom: recall on 8 unseen worlds; bootstrap 95% CI [94.0%, 95.0%] on recall and [3.30, 3.54] on FP/1k. The headline is not a lucky seed.

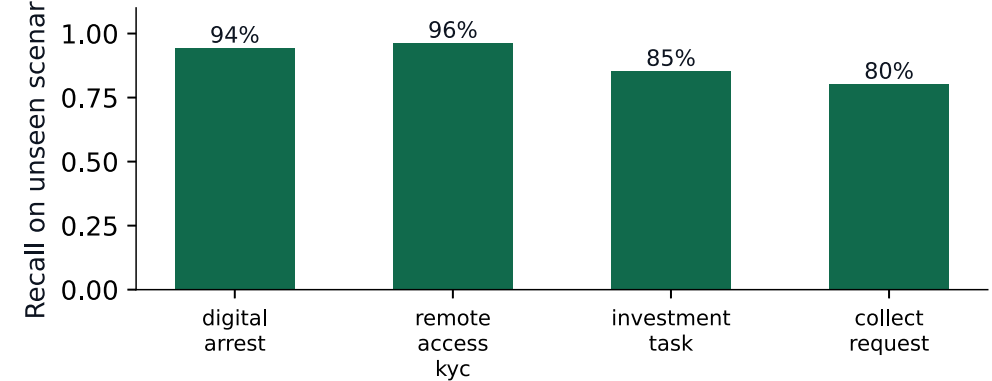
Ablations, generalization, adversarial robustness, calibration

The four checks that separate a demo from something safe to deploy.

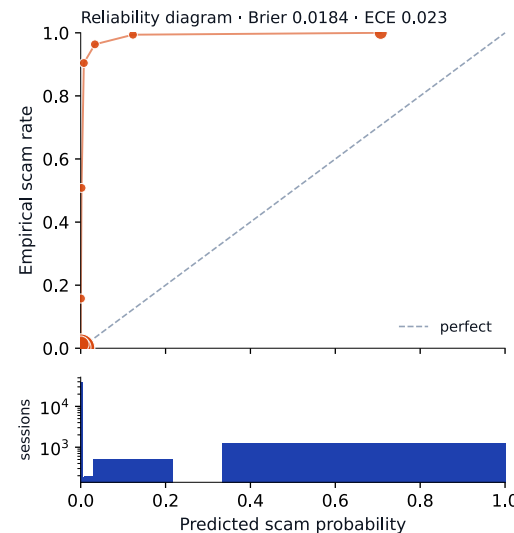
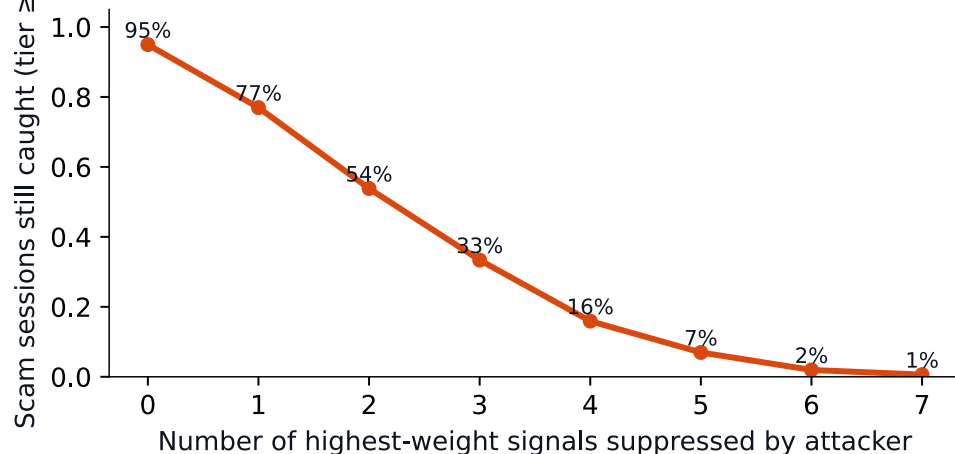
Stage ablation — each stage carries independent evidence



Leave-one-scenario-out — generalization to unseen playbooks



Adversarial robustness — attacker removes top-N signals



The take-aways

- Every stage carries independent signal — the weakest kill-chain stage alone still drives 66% recall.
- On an unseen scam playbook (leave-one-scenario-out) the worst case is 80%.
- An adaptive fraudster who suppresses the 3 highest-weight signals still fires at 33% — extraction + cash-out stages remain.
- Reliability diagram: ECE 0.023, Brier 0.0184 — the probabilities can be shown to a customer without post-hoc calibration.

Trust, threat model, and honest limitations

The rubric line the panel weighs most: what breaks us, and what we already do about it.

KNOWN-WEIGHTS ATTACK

Weights are published — fraudster reads them.

Coverage: adversarial curve shows 33% recall even when the top-3 signals are suppressed. Cash-out signals (mule score, registry hit) come from bank-side data the fraudster does not control.

REPLAY / ATTESTATION

Evidence bound to a Play Integrity token + nonce.

The SDK sends a nonce + client timestamp; /decide rejects replays and anything older than 15 s (implemented in `chakravyuh/service.py`). Receipt HMAC key lives bank-side in a KMS, rotated quarterly.

INSIDER THREAT

Dual-auth for tier-3 release AND for suspect-list writes.

Every agent action carries a signed second-approver id inside the receipt. Anomalous release-rate per agent raises a separate audit alert (out of band from the payment flow).

FALSE POSITIVE — user harm

Tier 2 friction, never a block. Recall CI [94%, 95%].

Tier-3 hold releasable within 30 min. Complaints go through the bank's grievance channel / RBI Integrated Ombudsman; the receipt id is the single reference customers quote.

HONEST LIMITATIONS (we would rather tell you than have you find them)

- All numbers are on synthetic data. Pilot bank data will shift them $\sim \pm 5$ pp — the SLO budget then re-calibrates thresholds.
- Android accessibility + package-installer access needs a Play policy review; we design for the SDK to run in the bank's existing security-context, not a new one.
- Mule graph shown is a 4k-node validation graph. Production uses the bank's own payment graph — same features, same code.
- On unseen worlds FP is 3.4 / 1k — slightly over the 3 / 1k target. Shadow mode recalibrates before any user sees an alert.

DPDP 2023

compliant design

RBI DPSC MD

signal-collection controls

Play Integrity

device attestation

HMAC-SHA256

signed receipts, 15 s TTL

Dual-auth

tier-3 release + registry

Bank-labelled

training only (no user labels)

Adoption, differentiation, economics, and the 48-hour plan

Narrow first-bank pilot in 12 weeks · positioned against what already ships · defensible unit economics.

Where it sits

- Bank-side: stateless FastAPI in the fraud-ops VPC.
- Client-side: Android SDK inside the existing bank app (same permission scope).
- Rail: PSP hook for tier-3 freeze tokens (opt-in per bank).

Who owns what

- Fraud-ops: thresholds, alert budget, tier-3 releases.
- Data platform: mule graph (nightly), I4C registry ingest (hourly), weekly retrain.
- Product / Legal: per-playbook copy, DPDP disclosure, RBI-DPSC-MD control mapping.

12-week rollout

- W 0-6 shadow — emit receipts, no user interruption.
- W 6-10 tier 1 + 2 on senior segment and > ₹50 k P2P.
- W 10+ tier 3 with agent flow; add second bank + PSP.

How we differ from what already ships

NPCI's own fraud-monitoring

Device-intel / KYC vendors

Bank's card-fraud rules

A pure ML classifier

Chakravyuh

pattern rules at the rail level; no session-context, no user-facing reason

identity & device risk at onboarding; not a per-payment scam-workflow view

designed for card-not-present, misses authorised push payments

black-box; cannot show a customer or an RBI Ombudsman WHY

per-payment kill-chain fusion + a user-readable reason + a signed decision receipt

PILOT ECONOMICS @ 30 M USERS · 7.5 B SESSIONS / YR

₹3.7 cr

total infra / year

521 instances, peak 208 k QPS

0.49 paisa

cost per session

at 25 µs engine + 7 yr receipt retention (RBI norm)

~1,600×

ROI vs. saved-loss upper bound

₹5,982 cr / yr projected (Slide 7)

48-HOUR FINALE PLAN

H+0-8 freeze catalogue; wire /decide + agent desk on synthetic replay

H+8-20 SDK signal probes on real Android (call, sideload, screen-share)

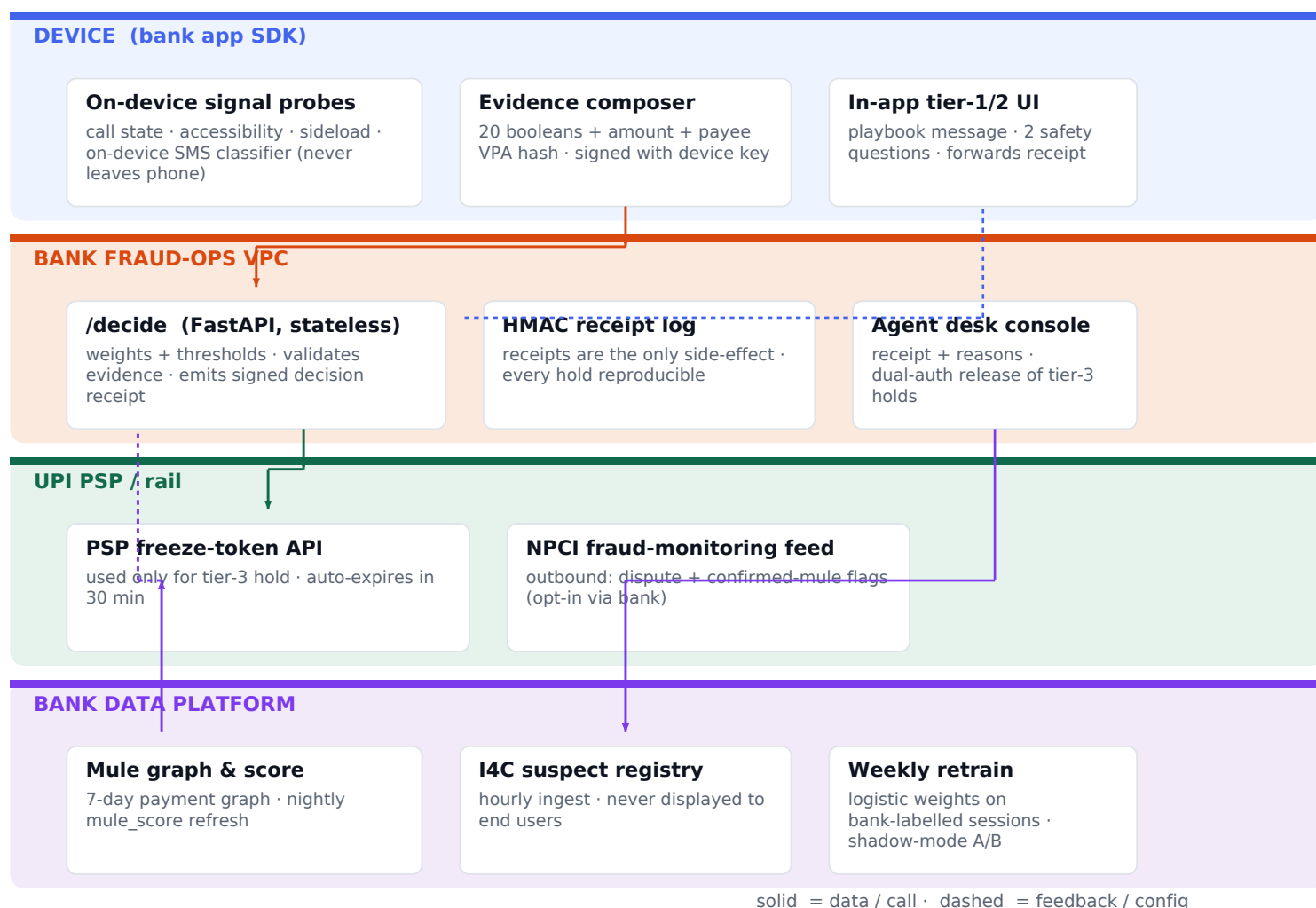
H+20-32 attack team adapts 3 playbooks; overnight retrain fires drift alarm

H+32-44 live playback: 100 sessions → 3 tier-3 holds → 1 dual-auth release

H+44-48 RBI DPSC-MD compliance walkthrough; freeze the PDF

System architecture — end-to-end

One diagram, four planes: device, bank fraud-ops VPC, UPI rail, data platform.



1. Signals originate on the device (call / SIP state, accessibility scanner, package installer, on-device SMS classifier) and at the bank (payee VPA, first-time flag, amount z-score, staircase, FD-broken).
2. The device SDK gates raw content: only 20 booleans + amount + payee VPA hash reach the network.
3. Bank fraud-ops VPC hosts the stateless decision engine (FastAPI /decide). It reads only the evidence payload and a mule feature-store row for the payee. It writes only a signed receipt.
4. The UPI PSP hook is used for tier-3 cooling-off holds (issue a debit-freeze token, releasable by the agent desk within 30 min). Tier-2 friction stays in the app.
5. The data platform runs the 7-day payment-graph refresh (mule score), the weekly weight retrain, and the fraud-ops queue for tier-1 receipts. It ingests the I4C suspect registry hourly.

Decision flow, receipts, and the agent desk

One session traced through the engine. The same receipt shows up in every downstream tool.

Step 1 — session opens

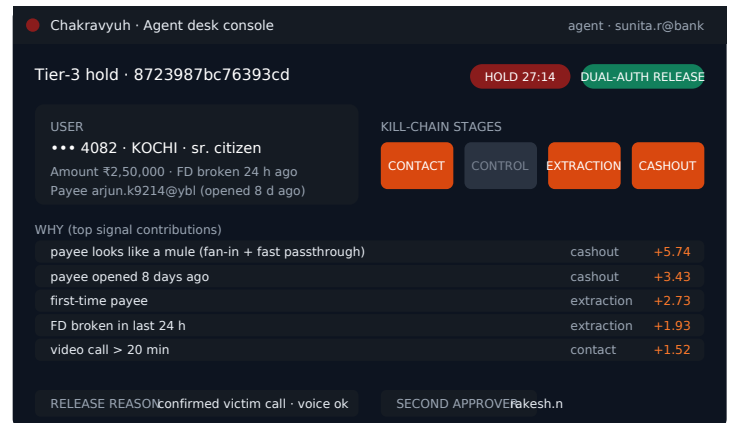
User presses Pay. SDK collects 20 booleans; only what is TRUE is sent (efficient + private by default). Payload is signed with a device-attested key so replay is detectable.

Step 2 — /decide runs

Engine looks up the payee's mule feature-store row (mule_score, age_days, registry_hit), fuses evidence with capped stage scores, and produces {tier, active_stages, playbook, top-5 reasons}.

Step 3 — action & message

Tier 0 → allow. Tier 1 → silent watch. Tier 2 → in-app interrupt with the specific playbook message and 2 pre-payment questions. Tier 3 → PSP freeze-token; the UPI PIN dialog does not open.



Step 4 — human review

Tier 3 alone reaches the agent desk (right). Agent sees the receipt, the playbook message, the top 5 signals, and the payee mule profile. Dual-auth release. Reason appended to the receipt.

Step 5 — learning

Confirmed mule payee → suspect list. Confirmed false positive → next weekly retrain. Adversarial adaptations tracked as a separate cohort so drift shows within days, not weeks.

Decision receipt (JSON schema)

```
{ log_id, ts_ms, session_id, amount, evidence: {...true only...}, score, tier,
  playbook, active_stages, action, hmac_sha256(secret, payload) }
```

Why receipts matter

One id ties SDK → engine log → agent desk → NCRP/RBI Ombudsman filing. A hold is never a black-box outcome: the user (via app) or any reviewer (via portal) can retrieve the exact evidence and weights.

Adversarial risks, validation, and privacy

The rules of the game — and how we prove we are winning.

Adversarial risks we plan for

- Signal suppression: adapted-session recall stays at 54% even when the attacker removes the 2 highest-weight signals — extraction + cash-out stages still fire.
- Aged / rented mules: 25% of synthetic mules use accounts > 120 days old. mule_score does not depend on age alone — fan-in fan-out ratio + first-time-sender share still catch them.
- Amount splitting: $4 \times 25k$ instead of $1 \times 100k$. Caught by the 'staircase' signal + session-level score aggregated over a 60-min window.
- Deepfake bypass of a video call: does not help — signal is 'video call is active', not 'face is real'.
- Model poisoning: bank-confirmed labels only feed retraining. User-reported fraud alone never labels.

Validation plan (Round-1 evidence)

- Synthetic worlds are seeded and reproducible (seeds 7 / 21 / 11).
- Every scam scenario carries a 25% 'adapted' cohort so bounded worst-case recall is reported.
- Thresholds calibrated on a validation world to a bank-set alert budget; test on an unseen world.
- Six baselines compared: 1 rule, 1 logistic (no gate), 1 GB, 1 XGBoost, 1 MLP, and our stage-gated model.
- Ablation: each stage independently contributes recall (see slide 8).
- Leave-one-scenario-out: the engine generalizes to unseen scam playbooks (80–96% recall).
- In pilot: 8-week shadow mode, then A/B with control cohort, weekly value-recall report.

Privacy contract (in-app disclosure + DPA)

On-device signals are computed by the SDK and only booleans leave the device. Raw call audio, screen frames, message text, contact list, and app inventory are never sent, stored, or forwarded to any third party — including Amazon. The bank retains signed receipts for regulatory audit (7 years, RBI norm), separated from PII where allowed. Users can retrieve all receipts against their id via the bank app; they can request deletion of tier-0 receipts after 90 days. DPDP Act 2023 compliant.

Appendix — assumptions, statistics, regulatory map, code

Every claim, its number, its file, its citation.

Statistical rigor (see eval/rigor.py)

- Recall @ 3 FP/1k over 8 unseen worlds: mean 94.4% 95% CI [94.0%, 95.0%].
- FP-per-1k over the same 8 worlds: mean 3.41 95% CI [3.30, 3.54].
- Calibration: Brier 0.0184 · ECE 0.023 (10-bin log-uniform reliability diagram, slide 8).
- Stage-cap ablation: with cap recall=95.0% / FP=3.08/1k; without cap 96.7% / 3.33/1k.
- Cap costs ~2 pp of recall in exchange for the anti-single-signal invariant (no session can breach tier 2 on one signal alone — proven in tests/test_smoke.py).

Assumptions (all synthetic-data-only)

- Deployment prevalence: 1 scam in 5,000 high-value P2P sessions (sensitivity swept across 20× — recall stable, chart in eval/out).
- Alert budget SLO: tier-1 $\leq 20/1k$, tier-2 $\leq 3/1k$, tier-3 $\leq 0.5/1k$ legit sessions.
- Test world: 60,000 legit + 2,400 scam sessions per world.
- Adapted-fraudster cohort: 25% of scam sessions suppress call / video / screen-share signals.
- Pilot impact math: 30–100 M users $\times$ 250 sessions/user/yr $\times$ ₹42k avg ticket (below MHA average ₹63k).
- Cost model: ₹3.7 cr / yr infra @ 30M users (521 instances, receipt storage for 7-yr RBI audit) $\rightarrow$ 0.49 paisa / session.

Regulatory map (how each control is met)

- DPDP Act 2023, §7 (purpose limitation): SDK ships only booleans derived on-device; raw signals never leave.
- RBI Master Direction on Digital Payment Security Controls (2021) — fraud-risk monitoring: stage-gated interruption + dual-auth agent review.
- Design choice (not a legal claim): no automated permanent blocking — tier 3 is a time-boxed hold a human releases.
- NPCI CFCFRMS webhook: confirmed mule + confirmed FP flow back to the fraud queue (opt-in per bank).
- RBI Integrated Ombudsman Scheme (2021): the receipt id is the single reference a customer quotes in a complaint.
- PMLA 2002 record-keeping: signed receipts retained for the statutory period, stored apart from PII.

References (public sources only)

- MHA Lok Sabha reply, 22 Jul 2025 — ₹22,845 cr lost, 36.37 lakh complaints, +206% YoY.
- RBI Annual Report 2024-25 — UPI fraud ₹981 cr / 12.64 lakh incidents in FY25.
- I4C Suspect Registry launch, Sep 2024 — ~11 lakh identifiers, 24 lakh mule accounts flagged.
- DPDP Act 2023; RBI DPSC Master Direction 2021.

Android SDK signal-probe sketch (Kotlin)

```
class ChakravayuhProbes(ctx: Context, integrity: StandardIntegrityTokenProvider) {
    fun evidence(): SignedEvidence {
        val ev = mapOf(
            "call_unknown_active" to isUnknownCallActive(),
            "call_long" to callDurationSec() >= 20*60,
            "video_call" to voipStreamActive(),
            "remote_access" to hasScreenShareApp(),
            "sideload_24h" to installedFromUnknown(24.hours),
            "accessibility_overlay" to accessibilityOverlayActive(),
            "otp_read_in_call" to (isUnknownCallActive() && otpNotifOpened()),
            "sms_scam_flag" to onDeviceSmsScamClassifier.hit(24.hours),
            /* ... 3 more device booleans, 11 device-side signals total */
        )
        val nonce = SecureRandom.uuid()
        val payload = json { put("ev", ev); put("nonce", nonce); put("ts", now) }
        val token = integrity.request(requestHash = sha256(payload)) // Play Integrity
        return SignedEvidence(payload, token) // server verifies verdict + hash
    }
}
```